Listing 6.11 Scanning the image for vulnerabilities and publishing it

```
name: Commit Stage
on: push

env:
  REGISTRY: ghcr.io
  IMAGE_NAME: polarbookshop/catalog-service
  VERSION: latest

jobs:
  build:
    ...
  package:
    ...
    steps:
      - name: Checkout source code
        ...
      - name: Set up JDK
        ...
      - name: Build container image
        ...
      - name: OCI image vulnerability scanning
        uses: anchore/scan-action@v3                              ❶
        id: scan
        with:                                                     ❷
          image:
          ➥ ${{ env.REGISTRY }}/${{ env.IMAGE_NAME }}:${{ env.VERSION }}
          fail-build: false                                       ❸
          severity-cutoff: high
          acs-report-enable: true
      - name: Upload vulnerability report
        uses: github/codeql-action/upload-sarif@v2               ❹
        if: success() || failure()
        with:
          sarif_file: ${{ steps.scan.outputs.sarif }}
      - name: Log into container registry
        uses: docker/login-action@v2                              ❺
        with:
          registry: ${{ env.REGISTRY }}                           ❻
          username: ${{ github.actor }}                           ❼
          password: ${{ secrets.GITHUB_TOKEN }}                   ❽
      - name: Publish container image                             ❾
        run: docker push
        ➥ ${{ env.REGISTRY }}/${{ env.IMAGE_NAME }}:${{ env.VERSION }}
```

❶ Scans the release candidate image for vulnerabilities using grype

❷ The image to scan is the release candidate.